

Security Test Report

FalconStrix – IDOR Assessment on Alert Resolution Endpoint

Report ID	FALSTRX-2026-005
Component Tested	/api/alerts/<id>/resolve
Vulnerability Class Tested	Insecure Direct Object Reference – CWE-639
Result	No vulnerability – behavior confirmed intentional
Discovered By	Manual black-box testing (Burp Suite), multi-account comparison
Environment	Isolated local lab – Windows 11 target, Kali Linux (VMware) attacker
Assessment Date	26 July 2026
Status	Closed – No Action Required

1. Summary

Testing was performed to determine whether /api/alerts/<id>/resolve is vulnerable to Insecure Direct Object Reference (IDOR) — specifically, whether one authenticated user could resolve alerts that were created by, or otherwise belonged to, a different user account, without proper authorization. The endpoint was confirmed to allow cross-account resolution; however, further testing showed this is **consistent with the application's intended design** as a shared, multi-operator SOC queue, and does not constitute a security vulnerability. This report documents the methodology and evidence supporting that conclusion.

2. Methodology

- Three distinct user accounts were used: zaid, humza, and admin, spanning both non-admin and admin roles.
- Manual alerts were created under separate account sessions to establish clear per-account test data.
- Using Burp Repeater, cross-account resolve requests were sent — e.g. an alert created under one session was targeted for resolution using a different account's session cookie and CSRF token.
- A control test was performed against a non-existent alert ID to check baseline server-side validation.
- The application's own UI was inspected for each account/role to determine whether the “Solve” action is presented as universally available, or scoped/hidden based on alert ownership.

3. Evidence

3.1 Cross-account resolution succeeds

```
POST /api/alerts/233/resolve HTTP/1.1
Host: 192.168.1.7:5001
Cookie: session=<Account A session>
```

```
X-CSRFToken: <valid token for Account A>
```

```
--- Response ---
```

```
HTTP/1.1 200 OK
```

```
{"ok": true, "result": {"fsm_unlock": {"changed": false}}, ...}
```

The same result (200 OK, "ok": true) was independently reproduced for alert IDs 234 and 235 across different account sessions, confirming any authenticated account could resolve any alert regardless of which account created it.

3.2 Control test – non-existent alert ID

```
POST /api/alerts/99999/resolve HTTP/1.1
```

```
--- Response ---
```

```
HTTP/1.1 404 NOT FOUND
```

```
{"ok": false, ...}
```

This confirms the endpoint does perform basic existence validation on the alert ID — the lack of an ownership check is a deliberate scope boundary, not a symptom of missing validation altogether.

3.3 UI behavior matches API behavior across all tested roles

For all three accounts (zaïd, humza, admin), the “Solve” button on the Live Alerts page was equally visible and clickable for every listed alert, with no distinction based on which account originally created it. All three accounts were also equally able to create new manual alerts.

4. Analysis & Conclusion

A finding is classified as IDOR when there is a mismatch between the access boundary a system *implies* (via its UI, documentation, or evident design) and what it actually *enforces* server-side. In this case, no such mismatch exists: the UI presents alert resolution as a shared, universally available action for every logged-in operator, and the backend enforces exactly that — nothing more permissive than what the interface already offers to every account.

This is consistent with FalconStrix's purpose as a SOC (Security Operations Center) dashboard, where alerts typically represent shared, system-wide security events intended to be actionable by any operator on a shared incident queue — not personal data scoped to an individual account. Restricting alert resolution to only the creating user would, in this context, likely hinder legitimate team workflows rather than improve security.

Conclusion: Not a vulnerability. The behavior tested is an intentional design choice, correctly and consistently enforced across all tested accounts and roles.

5. Value of This Test

Recording negative results is a standard part of a rigorous security assessment. This test confirms the alert-resolution endpoint was deliberately evaluated for IDOR, using a methodology capable of detecting it (multi-account, cross-session testing plus a UI-vs-API consistency check), rather than left untested. It also demonstrates a secondary, positive finding: the endpoint correctly returns 404 for non-existent resources, indicating sound basic input validation.

6. Testing Environment

- Target: FalconStrix on Windows 11, Flask bound to 0.0.0.0:5001, isolated VMware network.
- Attacker: Kali Linux (VMware), Burp Suite Community Edition.
- Three distinct FalconStrix accounts used to establish cross-account test conditions.
- All testing performed exclusively against the researcher's own locally-hosted project.

This report documents a self-directed test on a personal project, produced for educational / methodology-practice purposes. The conclusion reflects the tested application's apparent design intent as reasoned from its own UI behavior, not a claim about how every similar application should be designed.